COMPTIA SECURITY+ SY0-701 | DOMÍNIO 2 · AMEAÇAS, VULNERABILIDADES E MITIGAÇÕES (22%)

Security+ 2.4 · Replay Attacks

Mestre CyberSec · **Aula 2.4 — Replay Attacks** (5:45) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

Resumo Executivo da Aula: Replay: capturar o handshake/token e REENVIAR pra se autenticar de novo. Pass-the-hash: usar o HASH da senha como autenticador direto NTLM (Mimikatz + PsExec) — movimento lateral. Session hijacking: roubar cookie de sessão ativa (via XSS ou on-path) e se passar pelo usuário. Defe

💡 Highlights que a prova CompTIA cobra

- Replay: reenvia o 'handshake' capturado — defesa: nonce/timestamp
- Pass-the-hash: usa O HASH (não a senha) — NTLM é vulnerável, Kerberos menos
- Session hijacking: rouba cookie — HttpOnly + HTTPS mitiga

🎯 Dicas de Prova & Cenários Típicos da Banca

- 'reuses captured authentication data' = replay attack
- 'uses an NTLM hash to authenticate' = pass-the-hash

🚨 Além do Vídeo: Conceitos Oficiais, Siglas e Armadilhas (Seção 2.4 — Replay Attacks)

Por que este aprofundamento é cobrado na prova?: O vídeo resume os tópicos práticos, mas o exame CompTIA SY0-701 cobra discernimento técnico rigoroso sobre as tecnologias e protocolos específicos desta seção:

• Ataque de Replay

Ataque que captura dados de autenticação válidos, como um handshake ou token, e os reenvia para se autenticar como o usuário original. Não quebra a criptografia; reutiliza credenciais capturadas.

⚠️ ***Armadilha CompTIA:*** *Gatilho: 'reuses captured authentication data' = replay attack. Defesa principal: nonce e timestamp para tornar o dado único e não reutilizável.*

• Pass-the-Hash (PtH)

Ataque que usa um hash de senha NTLM capturado como autenticador direto, sem quebrá-lo para texto claro. Comumente usa Mimikatz para extrair hashes e PsExec para movimento lateral.

⚠️ ***Armadilha CompTIA:*** *Gatilho: 'uses an NTLM hash to authenticate' = pass-the-hash. NTLM é vulnerável; Kerberos reduz esse risco.*

• Sequestro de Sessão

Ataque que rouba um cookie ou token de sessão ativo, frequentemente via XSS ou interceptação on-path, e o usa para se passar pelo usuário autenticado.

⚠️ ***Armadilha CompTIA:*** *Gatilho: 'steals session cookie' = session hijacking. Mitigações: HttpOnly e HTTPS impedem acesso via script e protegem o cookie em trânsito.*

• Nonce

Valor aleatório ou único usado uma vez em uma troca de autenticação para garantir atualidade e impedir replay de mensagens capturadas.

⚠️ ***Armadilha CompTIA:*** *Defesa contra replay: nonce torna cada handshake único. Se a prova citar 'number used once', é nonce.*

• Carimbo de Tempo

Valor de tempo incluído nos dados de autenticação para verificar atualidade e rejeitar mensagens antigas demais para serem válidas.

⚠️ ***Armadilha CompTIA:*** *Defesa contra replay: se o timestamp estiver fora da janela aceitável, a autenticação é negada. Distinga de nonce: tempo vs. valor único.*

• **NTLM**
Protocolo de autenticação desafio-resposta do Windows que pode ser abusado no pass-the-hash porque a posse do hash da senha é suficiente para autenticar.

⚠️ ***Armadilha CompTIA:*** *Gatilho: NTLM + hash = pass-the-hash. Kerberos é preferível e menos suscetível a esse tipo de ataque.*

• **Kerberos**
Protocolo de autenticação baseado em tickets que é menos vulnerável ao pass-the-hash que o NTLM por não depender do envio de hashes de senha para autenticar.

⚠️ ***Armadilha CompTIA:*** *Distinga: NTLM é associado a pass-the-hash; Kerberos usa tickets e é a alternativa mais segura em domínios Windows.*

• **HttpOnly**
Atributo de cookie que impede scripts do lado do cliente, como JavaScript, de acessar o cookie, reduzindo roubo de sessão via XSS.

⚠️ ***Armadilha CompTIA:*** *Mitigação de session hijacking: HttpOnly protege contra XSS; HTTPS protege o cookie em trânsito. Se a questão citar 'script access to cookie', responda HttpOnly.*

🏛️ Visão Didática, Analogias & Análise de Governança (GRC)

📌 Ataque de Repetição (Replay Attack)

🏠 **Analogia Intuitiva:** Imagine o controle remoto de um carro de luxo. Quando o dono aperta o botão para abrir a porta, o controle emite um sinal de rádio. Um criminoso escondido usa um gravador de áudio e captura exatamente aquela frequência. Mais tarde, no meio da noite, o criminoso vai até o carro e aperta 'play' no gravador. O carro ouve o sinal original gravado e destranca a porta, pois não sabe diferenciar a emissão ao vivo de uma fita reproduzida.

🔍 **Causa Raiz / Por que foi criado:** Protocolos de autenticação que validam apenas a credencial ou o hash da mensagem, mas ignoram a novidade (freshness) e o carimbo de tempo da transação. O atacante não precisa quebrar a criptografia nem saber a senha; basta retransmitir os pacotes gravados.

🛡️ **Visão do Auditor de GRC:** Auditar sistemas bancários, APIs de pagamentos e mecanismos de autenticação legado contra repetição; exigir rejeição compulsória de pacotes duplicados e uso de tokens criptográficos não reutilizáveis.

⚠️ **Como cai na Prova CompTIA:** Gatilho: 'attacker intercepts valid authentication tokens or network packets and retransmits them later to gain unauthorized access without decrypting the payload'. Resposta: Replay Attack.

📌 Nonce Criptográfico (Number Used Once)

🏠 **Analogia Intuitiva:** É como um banco distribuir senhas de atendimento numeradas: 001, 002, 003. Quando você entrega a senha 001 no caixa, o atendente rasga e joga o papel no triturador. Se um golpista achar pedaços da senha 001 ou tirar foto dela e tentar usá-la dez minutos depois, o atendente diz: 'Esta senha já foi consumida e não vale mais nada!'. O nonce é um número gerado aleatoriamente que só é aceito uma única vez.

🔍 **Causa Raiz / Por que foi criado:** Para invalidar gravações de rede, o servidor gera e envia ao cliente um valor imprevisível e efêmero. O cliente precisa assinar esse valor na sua resposta; o servidor confere se aquele nonce já foi utilizado e descarta qualquer requisição repetida.

🛡️ **Visão do Auditor de GRC:** Revisar especificações de APIs corporativas e webhooks; garantir que parâmetros de nonce e hash de validação estejam presentes em todas as transações sensíveis de transferência de dados.

⚠️ **Como cai na Prova CompTIA:** Gatilho: 'random or pseudorandom number issued in an authentication protocol to ensure that old communications cannot be reused in replay attacks'. Resposta: Nonce (Number Used Once).

📌 Carimbos de Data/Hora e Janelas de Tempo (Timestamping & Kerberos)

🏠 **Analogia Intuitiva:** É como um ingresso de cinema com data e hora exata: 'Válido exclusivamente para 21 de Outubro às 19h00'. Se alguém tentar entrar na sessão do cinema com esse ingresso no dia seguinte ou na semana que vem, o porteiro recusa na hora porque a janela de validade expirou. No protocolo Kerberos, computadores cujos relógios internos estejam desfasados por mais de 5 minutos não conseguem conversar.

🔍 **Causa Raiz / Por que foi criado:** Ao atrelar a validade da mensagem a um carimbo de data/hora sincronizado, a janela de oportunidade para um invasor capturar e retransmitir o pacote fica restrita a poucos segundos ou minutos. Pacotes com timestamps fora da janela de tolerância (time skew) são sumariamente descartados.

🛡️ **Visão do Auditor de GRC:** Auditar a infraestrutura de sincronização de relógios corporativos (NTP seguro); assegurar que servidores e estações Active Directory mantenham sincronia estrita (máximo de 5 minutos de desvio no Kerberos) para evitar falhas de autenticação.

⚠️ **Como cai na Prova CompTIA:** Gatilho: 'authentication protocol relies on synchronized system time and rejects tickets exceeding a maximum allowable time skew (typically 5 minutes) to defeat replay attacks'. Resposta: Kerberos / Timestamps.

📌 Identificadores e Tokens de Sessão Efêmeros (Unique Session IDs)

🏠 **Analogia Intuitiva:** É como a pulseira de papel colocada no seu pulso em um festival de música que se rasga e se destrói se você tentar retirá-la para passar a outra pessoa. Além disso, a cada nova compra feita no bar do evento, a pulseira é carimbada com uma marca diferente. Se alguém tentar usar uma foto da pulseira antiga, o sistema recusa.

🔍 **Causa Raiz / Por que foi criado:** Aplicações web que mantêm identificadores de sessão estáticos ou com tempo de vida infinito facilitam o sequestro de sessão (Session Hijacking). O uso de IDs de sessão randômicos, criptograficamente seguros e rotacionados após o login neutraliza o reuso de credenciais.

🛡️ **Visão do Auditor de GRC:** Fiscalizar parâmetros de cookies de autenticação em aplicações web: verificar uso compulsório dos atributos `Secure`, `HttpOnly` e `SameSite=Strict`, além de tempo de expiração curto para sessões inativas.

⚠️ **Como cai na Prova CompTIA:** Gatilho: 'countermeasure that regenerates a new session identifier upon successful user login to thwart session replay and fixation'. Resposta: Session ID Rotation / Ephemeral Session Tokens.

⚡ TABELA DE FIXAÇÃO RÁPIDA PARA O EXAME (CHEAT SHEET)

Cenário Típico de Exame / Situação Prática	Conceito Técnico & Resposta da Banca
Captura e retransmissão não autorizada de pacotes ou credenciais válidas para obter acesso indevido	**Ataque de Repetição (Replay Attack)**
Valor numérico aleatório de uso único incluído em mensagens para impedir retransmissões antigas	**Nonce (Number Used Once)**
Mecanismo no protocolo Kerberos que descarta pacotes antigos com base no relógio sincronizado	**Carimbo de Data/Hora (Timestamping & Time Skew de 5 min)**
Serviço de rede que precisa ser mantido seguro e sincronizado para garantir a integridade de autenticações	**NTP (Network Time Protocol)**
Prática de gerar um novo identificador exclusivo logo após a autenticação do usuário	**Rotação de ID de Sessão (Session ID Rotation)**
Ataque em que o invasor rouba um cookie de sessão ativo para navegar fingindo ser o usuário legítimo	**Sequestro de Sessão (Session Hijacking)**

✅ Perguntas de Treino Comentadas (10 Questões de Cenários Reais)

Cenários autênticos alinhados aos objetivos do exame. O gabarito com análise completa dos distratores encontra-se ao final.

QUESTÃO 1 · CENÁRIO DE EXAME

Uma aplicação web financeira aceita requisições de API assinadas para transferências de contas. Um testador de penetração grava uma requisição de transferência legítima e a envia novamente mais tarde, sem alterá-la. O servidor atualmente verifica apenas a assinatura digital. Qual controle deve ser adicionado para impedir esse ataque?

A) Calcular hash do corpo da requisição com SHA-256 antes de assiná-lo.

B) Incluir um valor imprevisível de uso único em cada requisição e rejeitar qualquer valor reutilizado.

C) Exigir TLS 1.3 para todas as conexões de API.

D) Forçar os usuários a trocar senhas a cada 90 dias.

QUESTÃO 2 · CENÁRIO DE EXAME

Durante um incidente, analistas descobrem que um atacante obteve material de credencial de uma estação de trabalho e o usou para se autenticar em vários servidores de arquivos. O atacante nunca quebrou a senha e nunca soube o valor em texto claro. Qual técnica de ataque isso descreve?

A) Session hijacking

B) Kerberoasting

C) Pass-the-hash

D) Ataque de replay

QUESTÃO 3 · CENÁRIO DE EXAME

Uma aplicação web armazena identificadores de sessão em cookies. Um testador de segurança demonstra que JavaScript injetado consegue ler o cookie de sessão e enviá-lo a um servidor externo. Qual atributo de cookie impede mais diretamente esse roubo específico baseado em script?

A) Secure

B) SameSite=Strict

C) HttpOnly

D) Domain

QUESTÃO 4 · CENÁRIO DE EXAME

Funcionários usam uma rede Wi-Fi pública. Um atacante na mesma rede captura um cookie de sessão autenticada enviado por HTTP e o usa para acessar a conta do funcionário. Qual mitigação aborda melhor esse risco?

A) Definir cookies de sessão com o sinalizador Secure e impor HTTPS com HSTS.

B) Armazenar identificadores de sessão no armazenamento local do navegador e validá-los apenas no lado do cliente.

C) Reduzir os tempos limite de sessão para cinco minutos.

D) Habilitar compressão e cache HTTP para a aplicação.

QUESTÃO 5 · CENÁRIO DE EXAME

Um domínio Windows usa autenticação Kerberos. Arquitetos de segurança querem garantir que um atacante que capture uma troca de autenticação válida não consiga simplesmente retransmiti-la mais tarde. Em qual mecanismo o Kerberos se baseia para limitar esse tipo de reutilização?

A) Um cache de hash NTLM

B) Um autenticador com carimbo de data/hora

C) Um cookie de sessão com SameSite

D) Um ticket de serviço permanente

QUESTÃO 6 · CENÁRIO DE EXAME

Uma organização quer reduzir o risco de um atacante que compromete uma estação de trabalho Windows usar material de credencial em cache para se autenticar em outros sistemas como administrador. Qual controle é mais eficaz?

A) Habilitar os sinalizadores HttpOnly e Secure em cookies do navegador.

B) Implantar o Credential Guard e restringir contas privilegiadas a sistemas de administração dedicados.

C) Implementar CAPTCHA na página de login da VPN.

D) Exigir criptografia AES para todas as contas de serviço Kerberos.

QUESTÃO 7 · CENÁRIO DE EXAME

Um protocolo de autenticação personalizado envia ao servidor uma resposta derivada da senha. Um atacante captura a resposta e se autentica com sucesso enviando exatamente a mesma resposta novamente. Qual mudança de projeto impede melhor isso?

A) Aumentar o comprimento mínimo da senha.

B) Codificar a resposta em Base64 antes da transmissão.

C) Usar um desafio aleatório gerado pelo servidor em cada tentativa de autenticação e incluí-lo na resposta.

D) Armazenar toda resposta derivada de senha em um banco de dados para auditoria.

QUESTÃO 8 · CENÁRIO DE EXAME

Uma aplicação web atribui um ID de sessão quando o usuário visita o site pela primeira vez e mantém o mesmo ID após o login. Um atacante pode definir um ID de sessão conhecido no navegador da vítima e usá-lo depois que a vítima se autenticar. Qual correção aborda melhor essa vulnerabilidade?

A) Marcar o cookie de sessão como HttpOnly.

B) Adicionar um nonce a cada requisição de login.

C) Regenerar o ID de sessão imediatamente após a autenticação bem-sucedida.

D) Habilitar autenticação NTLM para o servidor web.

QUESTÃO 9 · CENÁRIO DE EXAME

Alertas do SIEM mostram múltiplas autenticações NTLM bem-sucedidas de uma única conta de usuário para muitos servidores. A estação do usuário não registra entrada interativa de senha, e o processo de origem não é um navegador. Qual atividade é mais consistente com esses indicadores?

A) Cross-site scripting roubando cookies

B) Pass-the-hash usando um hash de credencial roubado

C) Replay de ticket Kerberos

D) Fixação de sessão

QUESTÃO 10 · CENÁRIO DE EXAME

Um sistema de autenticação multifator aceita um código de uso único de seis dígitos por cinco minutos. Um atacante intercepta um código válido e o usa dentro da janela permitida. Qual melhoria impede melhor a reutilização do mesmo código?

A) Aumentar o comprimento do código para oito dígitos.

B) Trocar o aplicativo autenticador por entrega via SMS.

C) Registrar cada código como usado e vinculá-lo à sessão ou desafio de autenticação específico.

D) Armazenar códigos emitidos no armazenamento local do navegador para validação mais rápida.

GABARITO COMENTADO COM ANÁLISE DE DISTRATORES

Questão 1: Alternativa B — Incluir um valor imprevisível de uso único em cada requisição e rejeitar qualquer valor reutilizado.

Uma assinatura digital prova integridade e origem, mas não impede que um atacante reenvie uma requisição válida capturada. Um nonce é um valor único e imprevisível usado uma vez; o servidor rastreia nonces usados e rejeita duplicatas. Hash, TLS e rota��ão de senha não impedem replay na camada de aplicação.

Questão 2: Alternativa C — Pass-the-hash

Pass-the-hash ocorre quando um atacante captura um hash de senha NTLM e usa esse hash como autenticador, sem quebrá-lo para texto claro. Session hijacking usa um token ou cookie de sessão roubado, Kerberoasting visa tickets de contas de serviço Kerberos, e replay envolve retransmitir uma mensagem de autenticação capturada.

Questão 3: Alternativa C — HttpOnly

HttpOnly impede que scripts do lado do cliente leiam o cookie, bloqueando o roubo via XSS. Secure garante que o cookie só seja enviado por HTTPS, SameSite limita o envio entre sites e Domain define onde o cookie é válido; nenhum deles impede diretamente o acesso por JavaScript.

Questão 4: Alternativa A — Definir cookies de sessão com o sinalizador Secure e impor HTTPS com HSTS.

O problema central é que o cookie de sessão é transmitido sem criptografia e pode ser capturado no caminho. Cookies Secure só são enviados por HTTPS, e HSTS impõe conexões HTTPS, evitando exposição em texto claro. Armazenamento no cliente, timeouts curtos e compressão/cache não impedem roubo de cookie on-path.

Questão 5: Alternativa B — Um autenticador com carimbo de data/hora

O Kerberos usa autenticadores que incluem um carimbo de data/hora e são criptografados com uma chave de sessão. O servidor verifica o carimbo para rejeitar autenticadores antigos ou reutilizados. Cache de hash NTLM está relacionado a Pass-the-Hash, cookies são tokens de sessão web, e tickets de serviço permanentes aumentariam o risco de replay em vez de impedi-lo.

Questão 6: Alternativa B — Implantar o Credential Guard e restringir contas privilegiadas a sistemas de administração dedicados.

O Credential Guard ajuda a isolar e proteger hashes de senha NTLM e outros segredos contra roubo, reduzindo o risco de Pass-the-Hash. Restringir contas privilegiadas a sistemas de administração dedicados limita o movimento lateral. Sinalizadores de cookie, CAPTCHA e criptografia Kerberos para contas de serviço não protegem diretamente hashes de credenciais em cache na estação.

Questão 7: Alternativa C — Usar um desafio aleatório gerado pelo servidor em cada tentativa de autenticação e incluí-lo na resposta.

Um desafio aleatório gerado pelo servidor, ou nonce, torna cada troca de autenticação única. Reutilizar uma resposta capturada não corresponderá ao novo desafio. Senhas mais longas, codificação Base64 e registro de respostas não impedem replay do valor de autenticação capturado.

Questão 8: Alternativa C — Regenerar o ID de sessão imediatamente após a autenticação bem-sucedida.

Isso descreve fixação de sessão: o atacante fixa um ID de sessão conhecido antes do login e o reutiliza depois. Regenerar o ID de sessão após a autenticação invalida o ID conhecido pelo atacante. HttpOnly ajuda contra roubo por XSS, mas não contra fixação, nonces de login tratam replay, e NTLM não se relaciona ao gerenciamento de sessão web.

Questão 9: Alternativa B — Pass-the-hash usando um hash de credencial roubado

Autenticações NTLM bem-sucedidas para muitos servidores sem entrada interativa de senha são um indicador comum de Pass-the-Hash, especialmente quando uma ferramenta usa um hash roubado como credencial. Roubo de cookie por XSS, replay de ticket Kerberos e fixação de sessão envolveriam cookies web ou artefatos Kerberos, não esse padrão de autenticação NTLM.

Questão 10: Alternativa C — Registrar cada código como usado e vinculá-lo à sessão ou desafio de autenticação específico.

Interceptar e reutilizar um OTP válido dentro da janela de validade é um ataque de replay. Marcar OTPs como usados e vinculá-los a uma sessão ou desafio impede que o mesmo código seja aceito duas vezes. Códigos mais longos, SMS e armazenamento no cliente não impedem replay e podem enfraquecer a segurança.